PQC DAILY STUDY SERIES

Trade-offs entre Performance e Segurança em Algoritmos PQC

Day 46 | Category: Conceitos Fundamentais de PQC Date: 2026-10-31 | DAILY MONITORING

Entendendo o Equilíbrio: Performance vs. Segurança em PQC

À medida que o mundo faz a transição para a Criptografia Pós-Quântica (PQC), engenheiros e tomadores de decisão enfrentam um desafio crítico: escolher o algoritmo certo. Essa decisão não se resume a apenas escolher a opção mais segura, mas a encontrar o equilíbrio correto entre segurança, performance e consumo de recursos para uma aplicação específica. Diferente dos algoritmos clássicos, onde os trade-offs são bem compreendidos, a PQC apresenta um novo conjunto de variáveis com implicações significativas no mundo real.

> **Por que não existe um algoritmo PQC "universal"?**
>
> O processo de padronização do NIST PQC selecionou um portfólio de algoritmos (ML-KEM, ML-DSA, SLH-DSA) precisamente porque diferentes casos de uso têm necessidades distintas. Um servidor de negociações de alta frequência tem requisitos de performance diferentes de um sensor IoT com recursos limitados, e uma chave de assinatura de firmware tem um perfil de risco diferente de uma chave de sessão TLS.

Métricas Chave na Análise de Trade-offs em PQC

Ao avaliar um algoritmo PQC, devemos considerar várias métricas chave de performance e segurança. A escolha ideal otimizará esses fatores com base nas restrições e nos requisitos de segurança do sistema.

- **Tamanho da Chave Pública:** Chaves maiores podem aumentar a latência em protocolos de rede como o TLS, pois exigem a transmissão de mais dados durante o handshake.
- **Tamanho do Criptograma/Assinatura:** Tamanhos maiores impactam o consumo de banda e podem ser um fator limitante em redes de baixa potência e longa distância (LPWAN) ou em aplicações de blockchain.
- **Custo Computacional:** O poder de processamento necessário para geração de chaves, encapsulamento/criptografia e desencapsulamento/descriptografia. Custos computacionais elevados podem levar a uma performance mais lenta e a um maior consumo de energia, uma grande preocupação para dispositivos alimentados por bateria e servidores de alto tráfego.

- **Nível de Segurança:** O NIST define níveis de segurança (1, 2, 3, 4, 5) que correspondem à dificuldade computacional de quebrar o algoritmo, comparados a algoritmos clássicos como o AES. Níveis mais altos oferecem mais segurança, mas geralmente com um custo de performance.

Comparativo dos Algoritmos PQC Padronizados

Vamos comparar os três principais padrões PQC do NIST em relação a essas métricas chave para ilustrar os trade-offs.

Algoritmo (Nível 1 do NIST)	Tipo	Tamanho da Chave Pública (bytes)	Tamanho do Criptograma/Assinatura (bytes)	Velocidade Relativa	Principal Caso de Uso
ML-KEM-512 (Kyber)	KEM	800	768	Muito Rápido	Troca de chaves em TLS, VPNs (sessões efêmeras).
ML-DSA-44 (Dilithium)	Assinatura Digital	1312	2420	Rápido	Atualizações de software, assinatura de código, certificados digitais.
SLH-DSA-128s (SPHINCS+)	Assinatura Digital	32	7856	Lento	Necessidades de assinatura de alta garantia e longo prazo, onde a velocidade não é crítica (ex: CAs raiz).

> **Observação:** Note o contraste gritante. O SLH-DSA tem uma chave pública minúscula, mas uma assinatura muito grande e é significativamente mais lento. ML-KEM e ML-DSA são muito mais rápidos e têm saídas menores, tornando-os adequados para protocolos de rede de alto volume, mas o tamanho de suas chaves é maior.

Aplicabilidade no Mundo Real: Escolhendo a Ferramenta Certa

- **TLS/SSH/VPNs:** Para trocas de chaves efêmeras, a velocidade e o baixo overhead do criptograma são primordiais. O **ML-KEM (Kyber)** é o claro vencedor aqui. Seus ciclos rápidos de geração e encapsulamento/desencapsulamento de chaves minimizam a latência do handshake, evitando uma experiência de usuário negativa em websites e reduzindo os tempos de conexão para shells seguros.

  - **Certificados Digitais & PKI:** Para assinar certificados, o tamanho da assinatura e a velocidade de verificação são importantes. O **ML-DSA (Dilithium)** oferece um bom equilíbrio, tornando-o adequado para Autoridades Certificadoras (CAs) e para assinar ativos da web. Suas assinaturas são maiores que as clássicas, mas permanecem gerenciáveis para a maioria do tráfego web.
- **Assinatura de Firmware & Software:** Aqui, a integridade da assinatura é primordial, mas a operação de assinatura ocorre com pouca frequência (durante o processo de build do software). A velocidade de verificação é mais importante, pois acontece a cada atualização. O **ML-DSA** é uma excelente escolha. Para as assinaturas de raiz de confiança mais críticas e de longo prazo, o mais lento, mas mais conservador **SLH-DSA (SPHINCS+)**, poderia ser usado, pois sua segurança se baseia em funções de hash, que são extremamente bem auditadas.

Auto-avaliação Diária

1. Por que o ML-KEM (Kyber) é preferido para handshakes do TLS 1.3 em vez de outros algoritmos PQC?
2. Quais são as principais desvantagens de usar o SLH-DSA (SPHINCS+) para assinar cada atualização de software de um dispositivo IoT?
3. Uma empresa está construindo um sistema de mensagens de alta performance e baixa latência. Eles precisam escolher um algoritmo de assinatura PQC para autenticação de mensagens. Com base na tabela, o ML-DSA ou o SLH-DSA seria uma escolha mais apropriada e por quê?